

Identifying the Top 5 assets and the strategy note

Choosing five, owning the rest: prioritization as an act of governance

Session objectives

By the end of this lab, the MERIDIAN group's Top 5 critical assets is produced, consolidated from the four subsidiary mappings entered in the previous lab, and the "critical assets" subsection is written into the group's strategy note.

What is learned here:

- **Justify** the Top 5 exercise by its two official anchor points, and not merely by common sense
- **Consolidate** subsidiary priorities into a group priority, which is an arbitration and not an addition
- **Defend** each line of the Top 5 with an argument that connects rating, dependencies and exposure
- **Articulate** this result with the strategy note opened in session 1, without rewriting anything in it

Prerequisites

- The subsidiary's instance stocked in the previous lab: business assets, supporting assets, security needs. It is the raw material; the Top 5 is EXTRACTED from the map, it is not invented in a meeting.
- The tutorial's relative-position ratings: they now become what they have always been, an instrument of decision.
- The strategy note from session 1, with its "context and target governance" subsection: the session builds on it.

Why five, and why it is an official move

First, defusing the objection that always comes up in committee: "why five? everything is important". The answer rests on two French reference texts, and it is their convergence that gives the exercise its force.

The first is the EBIOS Risk Manager guide, whose vocabulary the tutorial provided: in terms of volume, it states that « 5 à 10 valeurs métier constituent généralement une base suffisante pour orienter la suite de l'étude » ("5 to 10 business assets generally constitute a sufficient base to orient the rest of the study"). In other words, the risk assessment method of sessions 5 and 7 does not need a catalog; it needs a handful of well-chosen business assets, and today's Top 5 is literally its input data. The second is even more operational: in its priority preventive cyber measures published in 2023, ANSSI asks to « établir une liste priorisée des services numériques critiques de l'entité » ("establish a prioritized list of the entity's critical digital services"). The word counts: a PRIORITIZED list, ranked among the five moves the agency judges most urgent for any organization. The Top 5 is therefore neither a schoolroom exercise nor a consultant's flourish: it is a measure recommended by the national authority, and the natural output of the map built in the previous lab.

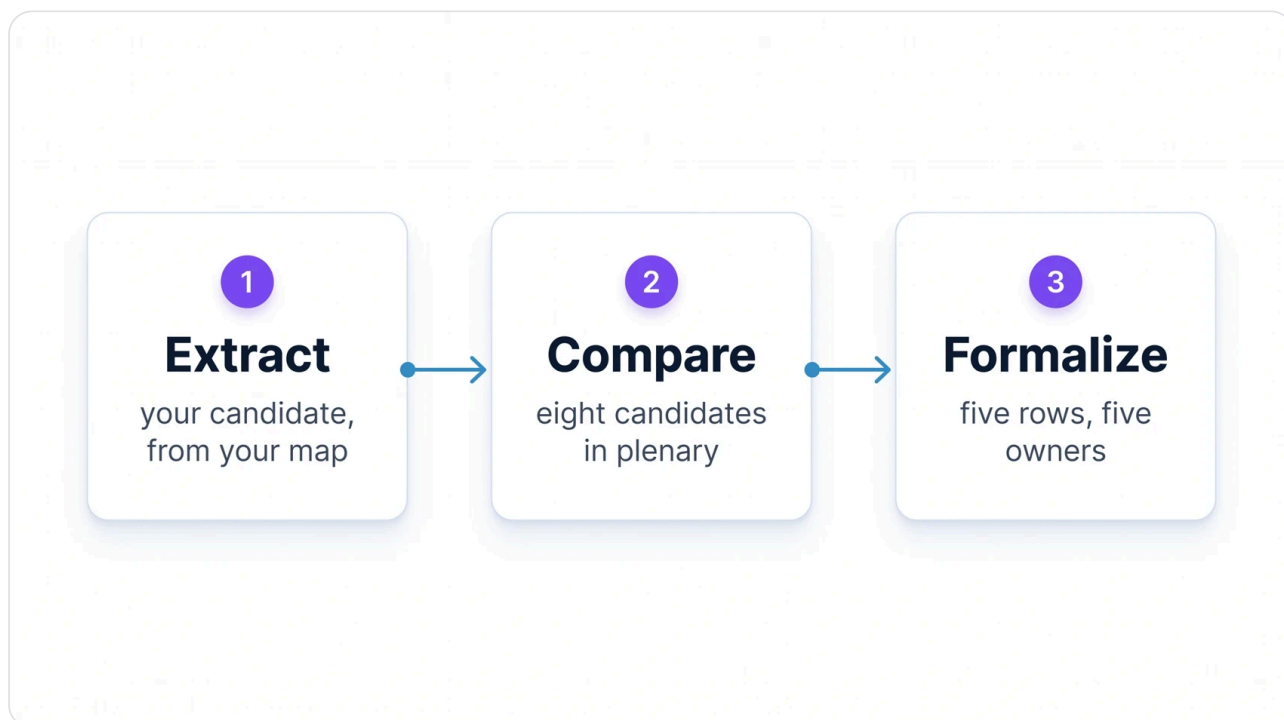
The profession, for that matter, is no longer mistaken about it: in the CESIN barometer published in 2026, 92 % of companies declare they have identified or are in the process of identifying their critical assets. This figure does not contradict this morning's 81 %, it illuminates it: declaring an identification effort in progress is not having a complete view of one's assets, and the whole gap between intention and a kept inventory lodges there. Identification has become the norm; what still distinguishes mature organizations is the ability to draw from it an owned priority, one that renounces, one that is written and signed. That is exactly this hour's move.

What the Top 5 is not, to clear up the classic misunderstanding: it is not the list of the five most expensive servers, nor of the five most fragile systems. It is the list of the assets, in the tutorial's full sense, business assets and the supporting assets that carry them, whose harm would hurt the group's mission the most. Fragility will cross paths with it later, at session 4's audit and then at the risk assessment; today the ranking is by what matters, not by what trembles.

In committee, the Top 5 is always presented with its explicit counterpart: "here are the five, and here is what that means for the rest". A priority that does not say what it deprioritizes will be contested line by line by everyone whose system is not on it.

Exercise: the group's Top 5, by confrontation

The consolidation plays out in three stages, and the second is the most instructive.



Three stages, and the second is the most instructive.

1. **Extract** from the subsidiary's instance the candidate for the group's Top 5: the asset, a business asset with its decisive supporting assets, whose harm would hurt the most, grounding the choice in the DICT ratings and not in the intuition of the moment. Two groups studied the same subsidiary without consulting each other, and that is the salt of the confrontation to come. The argument takes thirty seconds: what would be lost, for whom, and why it is worse than the rest of the subsidiary.

2. **Confront** in plenary the eight candidacies: each group presents, the others attack. Three arbitration criteria, in this order: business severity (what does the group lose?), inter-subsidiary dependencies (an asset on which two subsidiaries depend weighs more than its isolated equivalent, the emergency supply running thread is the canonical example), and the sector's exposure, because the threat is not uniform: ANSSI's latest panorama, on the incidents brought to its attention in 2025, places education and research at the top of the targeted sectors, about one third, ahead of ministries and local authorities (24 %) and healthcare (10 %). An Éducation subsidiary under-represented in the Top 5 should at the very least spark debate.

3. **Settle** the group's Top 5, five lines, each carrying: the asset, the subsidiary or subsidiaries concerned, the justification in one sentence mobilizing at least two of the three criteria, and the owner who will answer for it, in direct line with the morning's inventory rule.

Suggested time: 8 minutes of extraction, 12 of confrontation, 5 of formalization. The product: a five-line table, ready for the strategy note, each line of which would survive the question "why that one and not mine?" asked by a disgruntled subsidiary director.

Strategy note (15 minutes)

The module's ritual, third stage: the group's strategy note, opened in session 1 with the "context and target governance" subsection, is enriched today with its second subsection, "critical assets". Half a page at most, within the three-page limit of the complete document, and this cumulative exercise carries 10 points on the module's grading scale.

What the subsection contains: the settled Top 5, as a tight table; the method in two sentences, mapping entered into the group's tool then arbitrated consolidation, because a management team gives its trust to a result whose making it understands; and what this priority commits, the Top 5's counterpart sentence, what is a priority and what is less so. The articulation with session 1 is the most discriminating grading criterion: the "context and target governance" subsection laid down who decides and who arbitrates; the new subsection must lean on it explicitly, attaching the Top 5 to the bodies that will own it, the Group CISO for inter-subsidiary arbitration, the named owners for each asset. A budget argument can usefully close the subsection, and it is verified: for 2025, the CNIL issued nearly 487 million euros in sanctions; prioritizing protections on one's critical assets also means reducing exposure to that kind of bill.

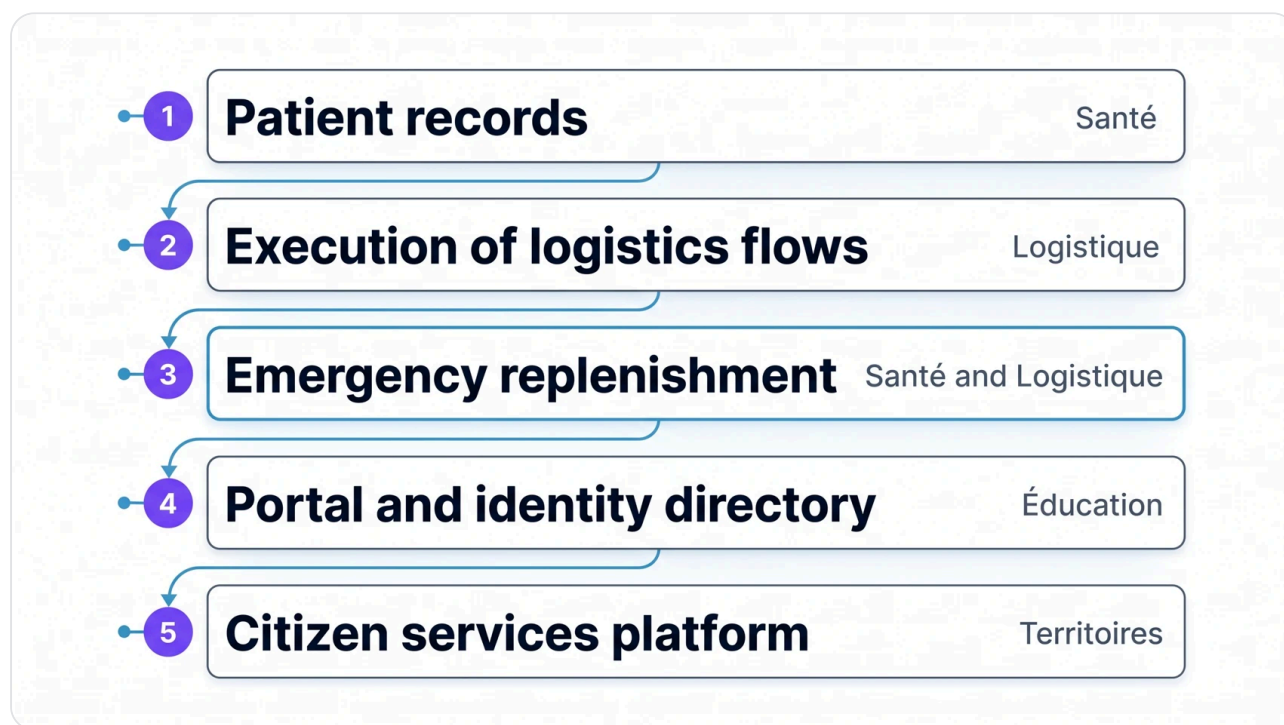
What the subsection does not contain: the complete list of assets (it lives in the tool, the note refers to it), the detailed ratings (same address), and any promise of an action plan, which belongs to the sessions to come.

And to close the session, the sentence that hands it on: the entered mapping and the settled Top 5 become, as of the next session, the material for the group's choice of framework, where what is regulatorily binding on each subsidiary will have to be qualified, and the yardstick chosen against which everything inventoried today will be evaluated.

Answer keys and assessment criteria

Answer key: a defensible Top 5, and the debates it must have gone through

There is no ONE correct Top 5; there are defensible Top 5s and limp Top 5s. Here is a defensible one, with its arguments, to compare afterwards. One: Santé's patient records, carried by the health data DBMS, maximum business severity and the group's most sensitive data. Two: the execution of logistics flows, carried by the WMS and the automated warehouses, the trucks stopping being the risk posed since session 1. Three: the inter-subsidiary emergency supply, the only asset on which TWO subsidiaries depend, handheld scanners, API, dedicated VLAN, the very example of the dependency criterion. Four: the teaching portal and identity directory of the Éducation & Territoires division, 45 000 accounts, a sector at the top of recorded incidents, and the shared administrator accounts noted as early as session 1, which mean a compromise on one side of the division spreads to the other. Five: Territoires' citizen services platform, backed by its administrative databases, some thirty client local authorities, regulated citizen data, and the exposure of a durably targeted public sector.



A defensible Top 5. Line 3 is the only one carried by two subsidiaries.

The debates a good plenary must have gone through: did Éducation deserve a place despite its limited budget? Yes, and it is the exposure criterion that saves it, against the reflex of ranking by subsidiary size. Should there have been a line for a supporting asset alone, the centralized SOC ramping up for example? Defensible, but the tutorial's method invites reasoning by the business assets carried; a SOC is decisive because business assets depend on it, and that is how it must be argued. Headquarters and its support functions? Absent from this answer key for lack of elements mapped today: a Top 5 contains only what the map knows, and this limit, stated honestly, is worth more than a decorative line.

Answer key: the "critical assets" subsection, written as a model

To be read after writing, never before. "In accordance with the governance settled at the opening of this document, the group has established the mapping of its information system in the common governance tool, subsidiary by subsidiary, then settled by arbitration of the Group CISO the prioritized list of its five critical assets: the patient records (Santé), the execution of logistics flows (Logistique), the inter-subsidiary emergency supply (Santé and Logistique), the teaching portal and identity directory (Éducation & Territoires division), the citizen services platform (Territoires). Each asset has a named owner; the detail of the ratings and supporting assets is kept in the tool, to which this document refers. This priority commits: the group's protection, audit and compliance efforts will bear first on these five assets, the other systems falling under standard treatment. It will be revised at every significant evolution of the mapping." The moves can be counted: the leaning on session 1's governance, the method in one sentence, the reference to the tool, the owned counterpart, the revision clause. Five sentences, no technical detail, everything a management team needs to know: that is the target.

Assessment criteria

CRITERION	INSUFFICIENT	EXPECTED	EXCELLENT
Subsidiary candidates	Chosen by intuition, with no link to the ratings	One candidate extracted from the instance, thirty-second argument	Same, with the explicit trace from DICT rating to candidacy
Confrontation	An addition of the proposals, without arbitration	The three criteria mobilized, at least one candidate set aside with a stated reason	Same, with the sector exposure debate actually held
Final Top 5	Lines without justification or without an owner	Five complete lines: asset, subsidiary or subsidiaries, two-criterion justification, owner	Same, and each line survives the "why that one and not mine?" test
Strategy note	The Top 5 copied without articulation	Half a page leaning on session 1's subsection, method and counterpart stated	Same, with the budget argument placed and the three-page limit held
Handover	Absent	The sentence toward next session's choice of framework	Same, explicitly linking Top 5, the subsidiaries' obligations and the evaluation to come